Command-and-Control im Red Teaming: Technische Analyse aktueller Frameworks und Implikationen für Obfuscation

Projektarbeit
im Studiengang Angewandte Informatik
an der Dualen Hochschule Baden-Württemberg Mannheim

von
Gabriel Ralf Ricarte Lanz

Abgabedatum: 27.08.2026

Bearbeitungszeitraum	08.01.2026-27.08.2026
Matrikelnummer, Kurs	6613445, TINF24AI1
Ausbildungsfirma	ABB AG
Betreuer	Tran, Jake
Unterschrift Betreuer	_____

Sperrvermerk

Der Inhalt dieser Arbeit darf weder als Ganzes noch in Auszügen Personen außerhalb des Prüfungsprozesses und des Evaluationsverfahrens zugänglich gemacht werden, sofern keine anders lautende Genehmigung des Dualen Partners vorliegt.

Erklärung

Ich versichere hiermit, dass ich meine Bachelorarbeit (bzw. Projektarbeit oder Studienarbeit bzw. Hausarbeit) mit den Themen: Automatisierte Analyse und Vergleich von Gruppenrichtlinienobjekten & Evaluierung von Verschleierungstechniken für Penetrationstests selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Ich versichere zudem, dass die eingereichte elektronische Fassung mit der gedruckten Fassung übereinstimmt.

Frankfurt am Main, den 27.08.2026

Ort, Datum	Unterschrift

Abstract

The present report focuses on the analysis of modern Command-and-Control (C2) frameworks in the context of Red Team operations. C2 infrastructures represent a core component of realistic attack simulations, as they enable the centralized control of compromised systems and the execution of post-exploitation activities.
The work provides a technical examination of contemporary C2 frameworks, with a particular focus on the Sliver framework. In addition, established solutions such as Metasploit and Cobalt Strike are comparatively assessed to identify architectural differences, operational characteristics, and typical use cases. The results contribute to evaluating the suitability of modern C2 frameworks for penetration testing as a service offering within the Service Central Cyber-Security (SZC) department and provide a foundation for further investigations in the area of payload and communication obfuscation.

Inhaltsverzeichnis

Sperrvermerk **i**

Erklärung zur Eigenleistung **ii**

Abstract **iii**

Abstract **iii**

Inhaltsverzeichnis **iv**

Abbildungsverzeichnis **vi**

Tabellenverzeichnis (Eigene Darstellung) **vii**

Abkürzungsverzeichnis **viii**

Überblick der Tätigkeiten der Praxisphasen **ix**

Vorwort **x**

1 Einleitung **1**
1.1 Ziel der Praxisarbeit 1
1.2 Einordnung von Command-and-Control (C2) im Red Teaming . 1
1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen 2

2 Theoretische Grundlagen **4**
2.1 Command-and-Control (C2) - Grundkonzept 4
2.1.1 Definition und Zweck von C2 4
2.1.2 Klassischer Kill-Chain Kontext 4
2.1.3 Beaconing und Kommunikation in C2-Frameworks 4
2.2 Anforderungen an moderne C2-Frameworks 5
2.2.1 Stealth und OPSEC 5
2.2.2 Modularität 5
2.2.3 Umgehung von EDR/AV-Systemen 5
2.2.4 Flexibilität und Anpassungsfähigkeit 5

3 Überblick über gängige C2-Frameworks **6**
3.1 Metasploit (MSF) 6
3.2 Cobalt Strike 6
3.3 Sliver 6

4 Sliver - Detaillierte Analyse **7**
4.1 Architektur 7
4.2 Funktionalitäten 7
4.2.1 Kommunikationsprotokolle 7
4.2.2 Payloads 7
4.2.3 Post-Exploitation 7
4.3 Stealth und OPSEC 7

5 Vergleichende Gegenüberstellung der C2-Frameworks **8**
5.1 Techischer Vergleich 8
5.2 Detection und Blue-Team-Sicht 8
5.3 Einsatzszenarien 8

6 Praxisbezug **9**
6.1 9

7 Obfuscation als logische Weiterentwicklung **10**
7.1 Identifizierte Schwachstellen moderner C2s 10
7.2 Motivation für Obfuscation 10
7.3 Ausblick auf kommende Praxisarbeit 10

8 Fazit **11**

Abbildungsverzeichnis

1 Cyber Kill Chain 2

Tabellenverzeichnis

1 Abkürzungsverzeichnis viii
2 Übersicht der Tätigkeiten während der Praxisphasen ix

Abkürzungsverzeichnis

Abkürzung	Bedeutung
ABB	Asea Brown Boveri
AD	Active Directory
IT	Informations Technologie
PAEN	Process Automation Energy Industries
SZC	Service Zentralbereich Cyber-Security
OPSEC	Operational Security
C2	Command and Control
EDR	Endpoint Detection and Response
SOC	Security Operations Center
SIEM	Security Information and Event Management

Tabelle 1: Abkürzungsverzeichnis

Überblick der Tätigkeiten der Praxisphasen

Nr.	Tätigkeit	Zeitraum	Praxisphase
1	Workshop der SZC Abteilung am Standort Frankfurt Praunheim	26.01.26-30.01.26	3
2	Themenbearbeitung: Social Engineering als Service Leistung	26.01.26-30.01.26	3
3	Themenbearbeitung: Command and Control Frameworks im Kontext von Penetration Tests	30.01.26 - 17.03.26	3

Tabelle 2: Übersicht der Tätigkeiten während der Praxisphasen

Vorwort

Die in dieser Arbeit beschriebenen Tätigkeiten wurden im Rahmen der dritten Praxisphase des Studiums bei der **ASEA Brown Boveri AG (ABB)** durchgeführt. Der Praxiszeitraum erstreckte sich über die vereinbarte Dauer der dritten Praxisphase. Die Tätigkeiten fanden an den Standorten Frankfurt am Main und Mannheim statt und wurden in der Abteilung **Process Automation Energy Industries (PAEN)**, konkret im **Service Zentralbereich Cyber-Security (SZC)**, unter der fachlichen Anleitung der betrieblichen Betreuer Philip Dosch und Jake Tran durchgeführt.

Gegenstand dieser Praxisarbeit ist die Analyse moderner **Command-and-Control-Infrastrukturen (C2)** im Kontext von Red-Team-Operationen. Der Schwerpunkt liegt auf der technischen Betrachtung aktueller C2-Frameworks, wobei insbesondere das Framework **Sliver** detailliert analysiert wird. Ergänzend erfolgt eine vergleichende Einordnung weiterer verbreiteter Lösungen, darunter unter anderem **Metasploit** und **Cobalt Strike**, um Gemeinsamkeiten, Unterschiede sowie jeweilige Einsatzszenarien herauszuarbeiten.

Im Rahmen der Arbeit werden zentrale Aspekte moderner C2-Frameworks untersucht, darunter Architekturkonzepte, Kommunikationsmechanismen, Payload-Generierung sowie operative Gesichtspunkte im Hinblick auf Stealth und OPSEC. Ziel ist es, ein fundiertes Verständnis für die Funktionsweise und den praktischen Einsatz dieser Infrastrukturen in realistischen Red-Team-Szenarien zu vermitteln.

Die Analyse zeigt zugleich, dass trotz fortschreitender Entwicklung moderner C2-Frameworks weiterhin erkennbare Schwachstellen in Bezug auf Erkennbarkeit, Signaturbildung und Verhaltensanalyse bestehen. Diese Erkenntnisse verdeutlichen die Notwendigkeit zusätzlicher Maßnahmen zur Tarnung von Payloads und Kommunikationsmustern, insbesondere im Umfeld zunehmend leistungsfähiger Endpoint-Detection-and-Response-Systeme.

Aufbauend auf den Ergebnissen dieser Praxisphase ergibt sich eine inhaltliche Überleitung zur vierten Praxisphase, in der der Fokus auf der vertieften Auseinandersetzung mit **Obfuscation-Techniken** liegen wird. Geplant ist dabei die Konzeption und Entwicklung einer eigenen **Obfuscation-Toolbox**, welche gezielt auf die im Rahmen dieser Arbeit identifizierten Schwachstellen moderner C2-Infrastrukturen eingeht und deren Einsatz in Red-Team-Operationen weiter optimiert.

Abschließend möchte ich mich bei meinen Praxisbetreuern, meinem Vorgesetzten sowie bei allen Kolleginnen und Kollegen der Abteilung bedanken, die mich während der dritten Praxisphase fachlich unterstützt haben und jederzeit für einen offenen Austausch zur Verfügung standen.

1 Einleitung

1.1 Ziel der Praxisarbeit

Die zunehmende Vernetzung industrieller Steuerungs- und Automatisierungssysteme führt zu einer wachsenden Angriffsfläche, insbesondere in sicherheitskritischen Betriebsumgebungen. Unternehmen, die im Bereich der Operational Technology (OT) und kritischer Infrastrukturen (KRITIS) tätig sind, stehen dabei vor der Herausforderung, sowohl regulatorische Anforderungen als auch steigende Bedrohungen durch hochentwickelte Angreifer zu adressieren. Vor diesem Hintergrund gewinnt die realistische Bewertung der eigenen Sicherheitsmaßnahmen zunehmend an Bedeutung.

Gegenstand dieser Praxisarbeit ist die technische Analyse moderner Command-and-Control-Frameworks (C2) im Kontext von Red-Team-Operationen. Im Fokus stehen dabei Architekturkonzepte, Kommunikationsmechanismen sowie operative Eigenschaften aktueller C2-Lösungen. Exemplarisch wird das Framework Sliver detailliert untersucht und mit weiteren etablierten Frameworks wie Metasploit und Cobalt Strike vergleichend eingeordnet.

Auf Basis dieser Analyse werden die Einsatzmöglichkeiten moderner C2-Frameworks im Rahmen realitätsnaher Angriffssimulationen bewertet. Dabei werden sowohl technische Kriterien als auch operationelle Gesichtspunkte wie Skalierbarkeit, Flexibilität und Stealth betrachtet. Die gewonnenen Erkenntnisse dienen als Grundlage für die Einordnung des praktischen Nutzens von C2-Infrastrukturen in professionellen Sicherheitsprüfungen und im Kontext angebotener Penetrationstests.

1.2 Einordnung von Command-and-Control (C2) im Red Teaming

Im Red Teaming stellt Command-and-Control eine zentrale Phase innerhalb der Cyber Kill Chain[1] dar. Nach erfolgreicher Kompromittierung eines Zielsystems ermöglicht eine C2-Infrastruktur die fortlaufende Steuerung kompromittierter Systeme, die Durchführung weiterer Aktionen sowie die Koordination komplexer Angriffsszenarien. Ohne eine funktionierende C2-Kommunikation ist eine nachhaltige und realitätsnahe Simulation moderner Angreifer nicht möglich.

Abbildung 1: Cyber Kill Chain

Im Gegensatz zu klassischen Penetrationstests, die häufig auf die Identifikation einzelner Schwachstellen fokussiert sind, zielt Red Teaming auf die Nachbildung vollständiger Angriffsabläufe ab. C2-Frameworks übernehmen hierbei die Rolle der zentralen Steuerungsinstanz und bilden die technische Grundlage für Post-Exploitation-Aktivitäten, laterale Bewegungen und persistente Zugriffsmechanismen. Ihre Ausgestaltung beeinflusst maßgeblich die Realitätsnähe und Aussagekraft einer Red-Team-Operation.

1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen

Mit dem Inkrafttreten der NIS-2-Richtlinie verschärfen sich die regulatorischen Anforderungen an Betreiber kritischer Infrastrukturen sowie an Unternehmen, die Dienstleistungen für diese bereitstellen. Insbesondere im OT- und KRITIS-Umfeld rücken Aspekte wie Angriffserkennung, Resilienz und kontinuierliche Sicherheitsbewertung stärker in den Fokus. ABB agiert in diesem Umfeld als Anbieter und Integrator industrieller Automatisierungs- und Prozessleitsysteme, deren Verfügbarkeit, Integrität und Sicherheit von zentraler Bedeutung sind.

Für den Service Zentralbereich Cyber-Security (SZC) ergibt sich daraus die Notwendigkeit, Sicherheitsprüfungen über rein technische Schwachstellenanalysen hinaus zu erweitern. Moderne C2-Frameworks ermöglichen es, realistische Angreiferverhalten nachzubilden und die Wirksamkeit bestehender Sicherheitsmaßnahmen unter praxisnahen Bedingungen zu evaluieren. Insbesondere im Rahmen von Penetrationstests als Serviceleistung bieten C2-Infrastrukturen die Möglichkeit, komplexe Angriffsszenarien kontrolliert zu simulieren und deren Auswirkungen auf IT- und OT-Umgebungen zu analysieren.

Die in dieser Praxisarbeit untersuchten C2-Frameworks leisten somit einen Beitrag zur Erhöhung der Aussagekraft von Sicherheitsprüfungen im regulierten Umfeld. Gleichzeitig bilden sie eine technische Grundlage für weiterführende Fragestellungen, etwa im Bereich der Tarnung von Payloads und Kommunikationsmustern, die im Kontext zunehmender Detektionsmechanismen an Bedeutung gewinnen.

2 Theoretische Grundlagen

2.1 Command-and-Control (C2) - Grundkonzept

2.1.1 Definition und Zweck von C2

Command-and-Control (C2) bezeichnet im Kontext von Cyberangriffen die Gesamtheit der Mechanismen und Infrastrukturen, die es einem Angreifer ermöglichen, kompromittierte Systeme zentral zu steuern. Nach erfolgreicher Kompromittierung eines Zielsystems dient eine C2-Infrastruktur dazu, Befehle an Implantate oder Schadsoftware zu übermitteln, Rückmeldungen zu empfangen und weitere Aktionen zu koordinieren. C2 stellt somit die kommunikative Verbindung zwischen Angreifer und Zielsystem dar und ist eine wesentliche Voraussetzung für nachhaltige und zielgerichtete Angriffe.[2]

2.1.2 Klassischer Kill-Chain Kontext

C2 ist als eigenständige Phase innerhalb der klassischen Cyber Kill Chain zu verstehen. Die Kill Chain beschreibt einen sequenziellen Angriffsablauf, der von der Aufklärung über die initiale Kompromittierung bis hin zur Zielerreichung reicht. In diesem Modell folgt die Command-and-Control-Phase typischerweise auf die erfolgreiche Ausführung und Installation eines Angriffsartefakts.

Wie in Abbildung 1 dargestellt, bildet C2 das Bindeglied zwischen der initialen Kompromittierung und den eigentlichen Angriffsaktionen. Erst durch eine funktionierende C2-Kommunikation wird es möglich, kompromittierte Systeme dauerhaft zu kontrollieren, weitere Befehle auszuführen und situativ auf Veränderungen in der Zielumgebung zu reagieren. Aus Sicht der Verteidigung stellt die C2-Phase zugleich einen zentralen Ansatzpunkt für Detektion und Unterbrechung von Angriffen dar.

Im Red Teaming wird dieser Kontext bewusst genutzt, um nicht nur einzelne Schwachstellen zu identifizieren, sondern vollständige Angriffsketten realistisch abzubilden. Die Qualität und Ausgestaltung der C2-Infrastruktur hat dabei direkten Einfluss auf die Aussagekraft der gesamten Angreifersimulation.

2.1.3 Beaconing und Kommunikation in C2-Frameworks

Die Kommunikation zwischen kompromittierten Systemen und einer Command-and-Control-Infrastruktur bildet einen zentralen Bestandteil moderner C2-Frameworks. Ziel ist es, Befehle und Rückmeldungen zuverlässig sowie möglichst unauffällig zu übertragen. Zu diesem Zweck unterstützen aktuelle Frameworks unterschiedliche Kommunikationsprotokolle, die sich an legitimen Netzwerkverkehr anlehnen und verschiedene Einsatzszenarien abdecken.

Ein verbreitetes Kommunikationsmodell ist das Beaconing, bei dem kompromittierte Systeme in regelmäßigen oder adaptiven Intervallen selbstständig eine

Verbindung zum C2-Server herstellen. Dieses Modell begünstigt ausgehenden Netzwerkverkehr und ist insbesondere in Umgebungen mit restriktiven Firewall-Regeln von Vorteil. Demgegenüber stehen sessionbasierte Modelle mit persistenten Verbindungen, die eine unmittelbare Interaktion ermöglichen, jedoch eine erhöhte Erkennbarkeit aufweisen können.

Zur Umsetzung dieser Modelle nutzen C2-Frameworks verschiedene Protokolle. Häufig kommt TLS-geschützter HTTP(S)-Verkehr zum Einsatz, da dieser in den meisten Netzwerken erlaubt ist und sich gut in regulären Web-Traffic integrieren lässt. Ergänzend werden DNS-basierte Mechanismen verwendet, um auch in stark eingeschränkten Netzwerken eine grundlegende Kommunikation zu ermöglichen. Moderne Frameworks unterstützen zudem verschlüsselte Tunnelverfahren wie WireGuard, die eine robuste und performante Kommunikation bei gleichzeitig hohem Sicherheitsniveau bieten.

Etablierte C2-Frameworks wie Cobalt Strike und Metasploit setzen diese Ansätze in unterschiedlicher Form um. Während klassische Meterpreter-Sessions überwiegend sessionbasierte Verbindungen nutzen, verwendet Cobalt Strike primär Beaconing-Konzepte über HTTP(S), DNS oder SMB. Viele aktuelle Frameworks kombinieren mehrere Protokolle und Kommunikationsmodelle, um flexibel auf unterschiedliche Zielumgebungen reagieren zu können.

Die detaillierte Betrachtung dieser Kommunikationsmechanismen sowie deren operative Auswirkungen erfolgt in den nachfolgenden Abschnitten dieser Arbeit.

2.2 Anforderungen an moderne C2-Frameworks

2.2.1 Stealth und OPSEC

2.2.2 Modularität

2.2.3 Umgehung von EDR/AV-Systemen

2.2.4 Flexibilität und Anpassungsfähigkeit

3 Überblick über gängige C2-Frameworks

3.1 Metasploit (MSF)

3.2 Cobalt Strike

3.3 Sliver

4 Sliver - Detaillierte Analyse

4.1 Architektur

- Server client modell - modulare Struktur - plattformübergreifend (Windows, Linux, macOS)

4.2 Funktionalitäten

4.2.1 Kommunikationsprotokolle

- (HTTP, HTTPS, DNS, etc.)

4.2.2 Payloads

- Staged vs. Stageless -Cross Compilation - Verschiedene Shell-Typen (Reverse Shell, Bind Shell, etc.)

4.2.3 Post-Exploitation

- Privilige Escalation - Enumeration - Persistence - Lateral Movement - Pivoting - Data Exfiltration

4.3 Stealth und OPSEC

- Verschleierungstechniken - Anti-Forensic Features - Erkennung von EDR/AV-Systemen - Vergleich zu cobalt strike

5 Vergleichende Gegenüberstellung der C2-Frameworks

In diesem Kapitel werden die zuvor vorgestellten C2-Frameworks anhand verschiedener Kriterien miteinander verglichen. Ziel ist es, die Stärken und Schwächen der einzelnen Tools herauszuarbeiten und eine fundierte Bewertung ihrer Eignung für unterschiedliche Anwendungsfälle im Red Teaming zu ermöglichen. Die Vergleichskriterien umfassen unter anderem die Benutzerfreundlichkeit, die Flexibilität bei der Anpassung von Payloads, die Fähigkeit zur Umgehung von Sicherheitslösungen sowie die unterstützten Betriebssysteme und Protokolle. Durch diese vergleichende Analyse soll ein umfassender Überblick über die Leistungsfähigkeit der verschiedenen C2-Frameworks gegeben werden, um eine informierte Entscheidung bei der Auswahl des geeigneten Tools für spezifische Angriffsszenarien zu erleichtern.

5.1 Techischer Vergleich

- Kommunikationsprotokolle - Payload-Generierung - Modularität - Erweiterbarkeit

5.2 Detection und Blue-Team-Sicht

- Signaturen - Verhaltensbasierte Erkennung - Netzwerkverkehrsanalyse

5.3 Einsatzszenarien

- Wann Sliver sinnvoller ist - Wann msf ausreicht - warum cobalt strike in manchen Fällen die bessere Wahl sein könnte

6 Praxisbezug

6.1

7 Obfuscation als logische Weiterentwicklung

7.1 Identifizierte Schwachstellen moderner C2s

7.2 Motivation für Obfuscation

7.3 Ausblick auf kommende Praxisarbeit

8 Fazit

Literatur

[1] „Was ist Cyber Kill Chain? — Microsoft Security“, besucht am 18. Feb. 2026. Adresse: https://www.microsoft.com/de-de/security/business/security-101/what-is-cyber-kill-chain.

[2] „Was ist C2? Command-and-Control-Infrastruktur erklärt — Varonis“, besucht am 19. Feb. 2026. Adresse: https://www.varonis.com/de/blog/was-ist-c2.